The tradeoff between confidence and trust relies on several factors. First is the design of the identity system. As illustrated by the phishing problem, the design of things like email, SMS, and URLs makes it difficult for people to use their experience wisely. Second, some confidence-inspiring techniques may be more costly than the use case can support or than the organization can afford. Finally, how well identity systems are governed and maintained has an impact on how much confidence we can have in them or how vulnerable we are. For example, the Target example in chapter 1 was caused by poor authorization practices that allowed the attackers to assume roles to administer the system using a contractor's credentials.

2.6.3 Technical confidence in identity systems

Confidence in identity systems is dependent on technical mechanisms that ensure identity information is verified, authenticated, and used correctly. Unlike trust, which involves human or organizational oversight, technical confidence is derived from cryptographic, procedural, and policy-based controls that limit the risk of identity fraud, impersonation, and unauthorized access.

One of the most important systems for achieving confidence is the system and processes for managing accounts. Identity information is not static. Rather, it evolves from the initial enrollment or signup to updates and use and then to eventual deactivation. Confidence can be bolstered by a robust process for proofing identity attributes when accounts are established. We also need to consider whether the attributes have been kept up to date, whether accounts can be revoked, and whether an account is still valid. Poor management of account lifecycles leads to mistaken or fraudulent attributes and stale credentials that are the basis for poor access decisions. The identity lifecycle is critical to maintaining confidence in digital identities over time. We will explore this topic in greater depth in chapter 3.

Another place where confidence is made or broken is the authentication system. Using stronger authentication mechanisms can provide greater confidence that the entity logging in is the same one who created the account. Different authentication factors provide different levels of assurance and protection against hacking and phishing. We will explore this topic as well in chapter 3.